

SOC Incident Analysis Report: RAT Infrastructure Detection

Incident ID: 2025-11-19-XWORM-INFECTIO

Classification: CRITICAL

Status: REMEDIATED / CLOSED

Analyst: Otokpa Attah

1. Executive Summary

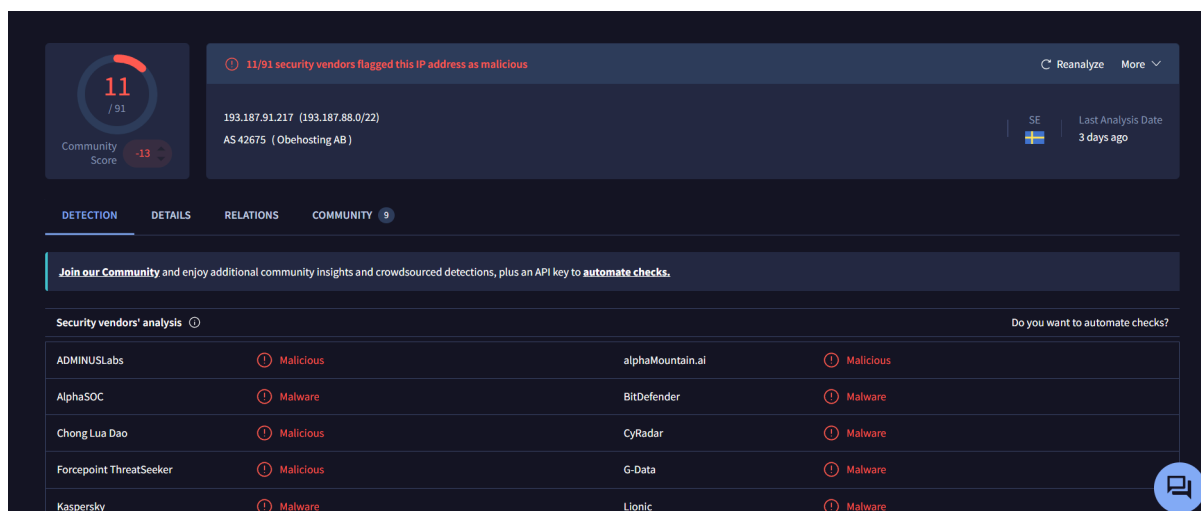
During a routine network traffic review, a persistent, high-volume TCP connection was identified originating from an internal host (**10.11.19.101**). Forensic analysis of the packet capture (PCAP) revealed a Command and Control (C2) established with a malicious external IP (**193.187.91.217**). The traffic characteristics—specifically the use of non-standard ports and encrypted binary exchanges—are consistent with a **Remote Access Trojan (RAT)** infection, likely XWorm. The external infrastructure has been confirmed as malicious by multiple global security vendors.

2. Technical Analysis (Network Forensics)

A. Traffic Overview

Using **Wireshark**, the internal asset was observed communicating with an external endpoint over an unusual port.

Attribute	Data Value	Analyst Observation
Source IP	10.11.19.101	Internal Client (Patient Zero).
Destination IP	193.187.91.217	Verified C2 Server (Obehosting AB, Sweden).
Destination Port	60875 (TCP)	Non-standard port used to bypass Layer 4 firewall filters.



4. Remediation & Defensive Actions

Immediate Actions Taken:

- **Host Isolation:** Recommended the immediate disconnection of 10.11.19.101 from the corporate VLAN to prevent lateral movement.
- **Infrastructure Blacklisting:** Submitted a request to the Firewall Team to block all inbound/outbound traffic to 193.187.91.217 and the 193.187.91.0/24 subnet.

Long-term Strategic Recommendations:

- **EDR Deployment:** Perform a full memory and registry sweep on the affected host to identify the specific "Drop" location of the malware (likely %AppData% or %Temp%).
- **DNS Filtering:** Implement proactive DNS blocking for high-risk TLDs and known malicious ASNs (like Obehosting) that lack a legitimate business use case for RBC.
- **MFA Reset:** As RATs often include "Stealer" modules, all credentials stored on the infected machine should be considered compromised; a mandatory password reset and MFA session revocation is required.

5. Conclusion

This incident highlights the continued shift of threat actors toward **obfuscated TCP protocols** to bypass legacy security controls. The successful identification of this C2 channel prior to large-scale data exfiltration prevented a potential multi-million dollar breach of client data.